

Docker Scout:

Ensuring Continuous Vulnerability Analysis

Docker Scout shifts container security from a static, point-in-time check to a dynamic, continuous process.



In modern software development, just scanning a container image once before deployment isn't enough. New security vulnerabilities (CVEs) are discovered daily, and an image that was 'safe' on Monday could be a critical risk by Tuesday.

This is the problem Docker Scout is designed to solve. It's an image analysis service that moves beyond static, one-time scans to provide dynamic, real-time security insights. It extracts a detailed software bill of materials (SBOM) and other metadata from your images and continuously evaluates this information against new and updated security advisories.

How Docker Scout works

Docker Scout operates in two distinct modes, each serving a different purpose

in your development lifecycle.

- **One-off local analysis:** When you analyse an image locally using the Docker CLI or Docker Desktop, Scout performs a scan, gives you the results, and moves on. It doesn't store any data about your image. This is perfect for quick checks during development.
- **Continuous platform analysis:** This is where Scout's true power lies. When you activate Docker Scout on a repository (like on Docker Hub or another integrated registry), it saves a metadata snapshot of your pushed images. This snapshot allows for dynamic evaluation. When a new vulnerability is disclosed, Docker Scout recalibrates the security status of your *existing* images using this saved metadata. You get real-time security updates for all your tagged images in the dashboard without ever needing to re-push or re-scan them.

How to analyse your images: Two key workflows

You can interact with Docker Scout from your registry (for continuous monitoring) or right from your local machine (for development and CI).

Registry-based analysis (the continuous method): This method is ideal for production workflows. Once you activate Scout on a repository, any new image you push is automatically analysed.

To trigger an analysis, simply push your image to the configured repository. For the most detailed and 'fine-grained' results, it is highly recommended to build

your image with flags that attach 'build attestations' (like SBOM and provenance):

```
# Build and push the image, attaching
# SBOM and provenance data
docker build --push --tag <your-
org>/<image:tag> \
  --provenance=true \
  --sbom=true .
```

After pushing, the image and its analysis results will appear on the 'Images' page in the Docker Scout dashboard.

Local analysis (for development and CI): You can get immediate feedback on images residing on your local machine using either Docker Desktop or the CLI.

When using Docker Desktop:

- Pull or build the image you want to analyse.
- Go to the 'Images' view in the Docker Dashboard.
- Select your image from the list to open the 'Image details' view, as shown in Figure 1. This view provides a full breakdown of the packages, layers, and vulnerabilities found by Docker Scout.

When you use the CLI, the *docker scout* commands offer powerful terminal-based tools.

- **docker scout quickview:** This command provides a high-level summary of your image and its base image. Its most powerful feature is comparing your current base image to a 'refreshed' version or an updated tag (like 'stable'),